

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/30/2025
Référence: Gestion de crise cyber
Destinataire: eddy

****Plan de Réponse à une Attaque par Ransomware****

****Domaine : Gestion de crise cyber****

****Scénario : Gestion d'une attaque avancée par ransomware****

****Niveau de difficulté : Expert****

****Contact : Lorenzo Bertola****

****Destinataire : Eddy****

****Contexte de l'Incident****

Le réseau interne de l'entreprise a récemment été compromis par une attaque de ransomware de type "double extorsion". Les attaquants ont non seulement chiffré les données critiques, mais ont également exfiltré des informations sensibles avant de lancer l'attaque. L'entreprise est confrontée à une demande de rançon élevée, accompagnée d'une menace explicite de publication des données volées sur le dark web si le paiement n'est pas effectué.

Le ransomware semble être une variante d'un logiciel malveillant connu pour son usage d'algorithmes de chiffrement asymétriques avancés (par exemple RSA-2048 ou AES-256), rendant le décryptage sans la clé privée pratiquement impossible. Les systèmes impactés incluent des serveurs de production, des bases de données critiques et des postes de travail de cadres supérieurs.

****Chronologie de l'Attaque****

- ****Jour 1 : **** Des activités inhabituelles ont été détectées sur plusieurs serveurs, incluant des pics de trafic réseau vers des adresses IP externes.
- ****Jour 2 : **** Plusieurs utilisateurs ont signalé une impossibilité d'accéder à des fichiers critiques, remplacés par des messages de demande de rançon (fichiers README.txt).
- ****Jour 3 : **** Une analyse préliminaire a confirmé la présence d'un ransomware actif, et les premières tentatives de restauration à partir de sauvegardes ont échoué.
- ****Jour 4 : **** Les attaquants ont contacté l'entreprise via une adresse e-mail dédiée et fourni une preuve de possession des données volées (exemple : capture d'écran d'informations internes sensibles).

****Détails Techniques****

- ****Vecteur d'entrée présumé : **** Phishing ciblé via des e-mails contenant des liens malveillants ou des fichiers infectés (ex. : macros dans des fichiers Word ou Excel).

- **Type de ransomware :** Variante avancée avec chiffrement asymétrique (possiblement dérivé de LockBit, Conti ou BlackCat).
- **Tactiques d'évasion :** Le ransomware semble avoir désactivé les solutions antivirus et empêché les sauvegardes automatiques via scripts PowerShell et modification de tâches planifiées.
- **Indicateurs de compromission (IoC) :**
 - Présence de fichiers avec extensions inhabituelles (.encrypted, .lockbit, etc.).
 - Connexions réseau vers des domaines non reconnus (ex. : *.onion).
 - Création de nouveaux comptes administrateurs sur les systèmes compromis.

Priorités Immédiates

1. **Containment :** Identifier et isoler les systèmes affectés pour éviter la propagation du ransomware à des zones non impactées.
2. **Évaluation des sauvegardes :** Vérifier l'intégrité des sauvegardes et déterminer si elles sont compromises ou utilisables.
3. **Communication interne :** Informer les parties prenantes clés sans provoquer de panique généralisée.
4. **Analyse des données sensibles :** Prioriser les données exfiltrées selon leur criticité (données financières, PII, informations stratégiques).
5. **Coordination externe :** Consulter des experts en réponse aux incidents, cabinets spécialisés en négociation de ransoms, et potentiellement les autorités locales.

Considérations Juridiques et Réglementaires

- **RGPD/GDPR :** Si des données personnelles ont été exfiltrées, une notification rapide aux autorités de protection des données est requise.
- **Obligation de signalement :** Vérifiez si des obligations de déclaration existent envers les clients, partenaires ou régulateurs.
- **Impact réputationnel :** Préparez un plan de communication externe en cas de fuite publique des données.

Éléments Historiques Pertinents

- Plusieurs attaques similaires ont été menées par des groupes tels que REvil et DarkSide, avec une tendance croissante à la double extorsion. Ces attaquants exploitent souvent des vulnérabilités non corrigées ou des mauvaises pratiques de gestion des accès (ex. : mots de passe faibles).
- Une étude de 2022 publiée par l'ENISA a révélé que 58% des attaques par ransomware incluent une phase d'exfiltration de données avant le chiffrement.

Questions à Considérer

- Quels systèmes doivent être prioritairement isolés pour limiter la propagation ?
- Comment établir une communication sécurisée avec les attaquants sans compromettre davantage le réseau ?
- Quelle stratégie adopter pour préserver la réputation de l'entreprise tout en répondant aux exigences légales ?

- En cas de restauration des sauvegardes, quelles étapes supplémentaires sont nécessaires pour garantir une reprise sécurisée ?

****Contact : Lorenzo Bertola (Responsable de la Gestion de Crise)****

Pour toute clarification ou support technique, veuillez me contacter via le canal sécurisé interne.

